

- **Lab Title:** Web Application Reconnaissance and Vulnerability Discovery Lab
- **Assignment Title:** Web Application Reconnaissance and Vulnerability Discovery Lab
- **Student Name:** Bashir Adam
- **Student ID:** 2025/FWSD/11509
- **Course Name:** BVWS102 – OWASP Top 10 Vulnerabilities & Exploitation Techniques
- **Instructor Name:** Aminu Idris
- **Date of Submission:** 26 DEC, 2025
- **Version:** Version 1.2.0

LAB OVERVIEW/OBJECTIVE

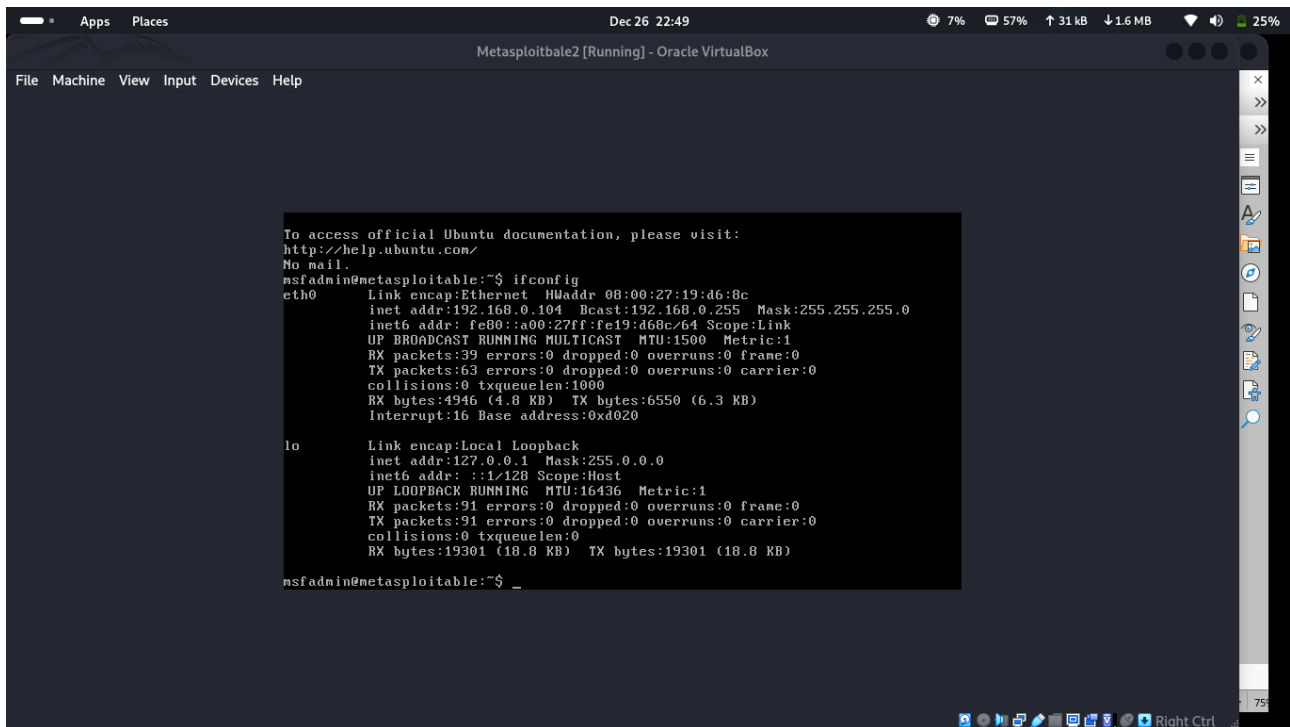
This lab is designed to help students gain hands-on experience in information gathering, enumeration, directory discovery, database exploration, and SQL injection testing using real-world tools and vulnerable environments. Students are expected to document clear evidence (screenshots, commands, outputs) for every task performed.

Lab Requirements

- Kali Linux (Attacker Machine)
- Metasploitable2 (Target Machine)
- Internet Access (for subdomain enumeration)
- Tools:
 - ü WhatWeb
 - ü Sublist3r
 - ü KnockPy
 - ü Dirb
 - ü MySQL Client
 - ü Burp Suite
 - ü Mutillidae (running on Metasploitable)

Part 1: Technology Fingerprinting with WhatWeb

From my metasploitable2 this is my IP address 192.168.0.104



```
Metasploitbale2 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

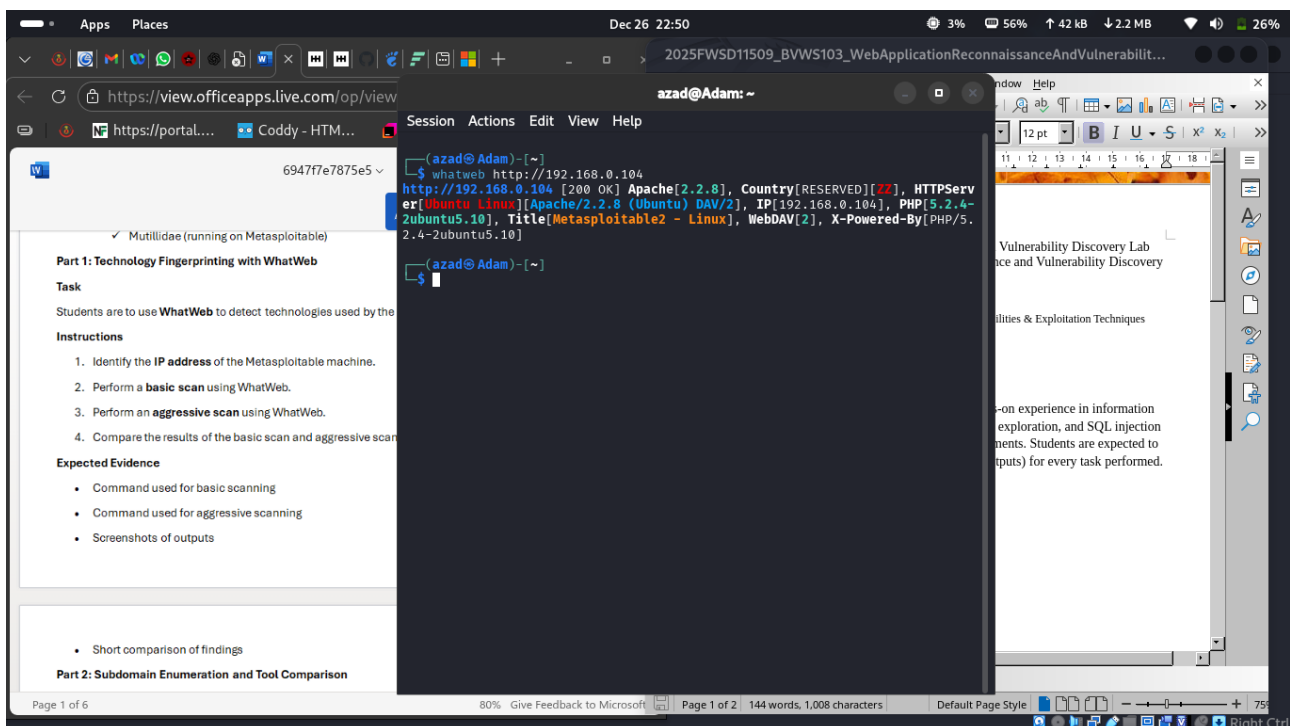
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:19:d6:8c
          inet addr:192.168.0.104  Bcast:192.168.0.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe19:d68c/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:39 errors:0 dropped:0 overruns:0 frame:0
          TX packets:63 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:4946 (4.8 KB)  TX bytes:6550 (6.3 KB)
          Interrupt:16 Base address:0xd020

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:91 errors:0 dropped:0 overruns:0 frame:0
          TX packets:91 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19301 (18.8 KB)  TX bytes:19301 (18.8 KB)

msfadmin@metasploitable:~$ _
```

I used the basic command of the whatwab to gather some information using the command:
whatweb <http://192.168.0.104>

This is direct and general information not deep



The screenshot shows a web browser window with a document titled "Part 1: Technology Fingerprinting with WhatWeb". The document contains instructions for a task and a list of expected evidence. A terminal window is open in the foreground, showing the output of the 'whatweb' command.

Part 1: Technology Fingerprinting with WhatWeb

Task

Students are to use **WhatWeb** to detect technologies used by the

Instructions

1. Identify the **IP address** of the Metasploitable machine.
2. Perform a **basic scan** using WhatWeb.
3. Perform an **aggressive scan** using WhatWeb.
4. Compare the results of the basic scan and aggressive scan

Expected Evidence

- Command used for basic scanning
- Command used for aggressive scanning
- Screenshots of outputs

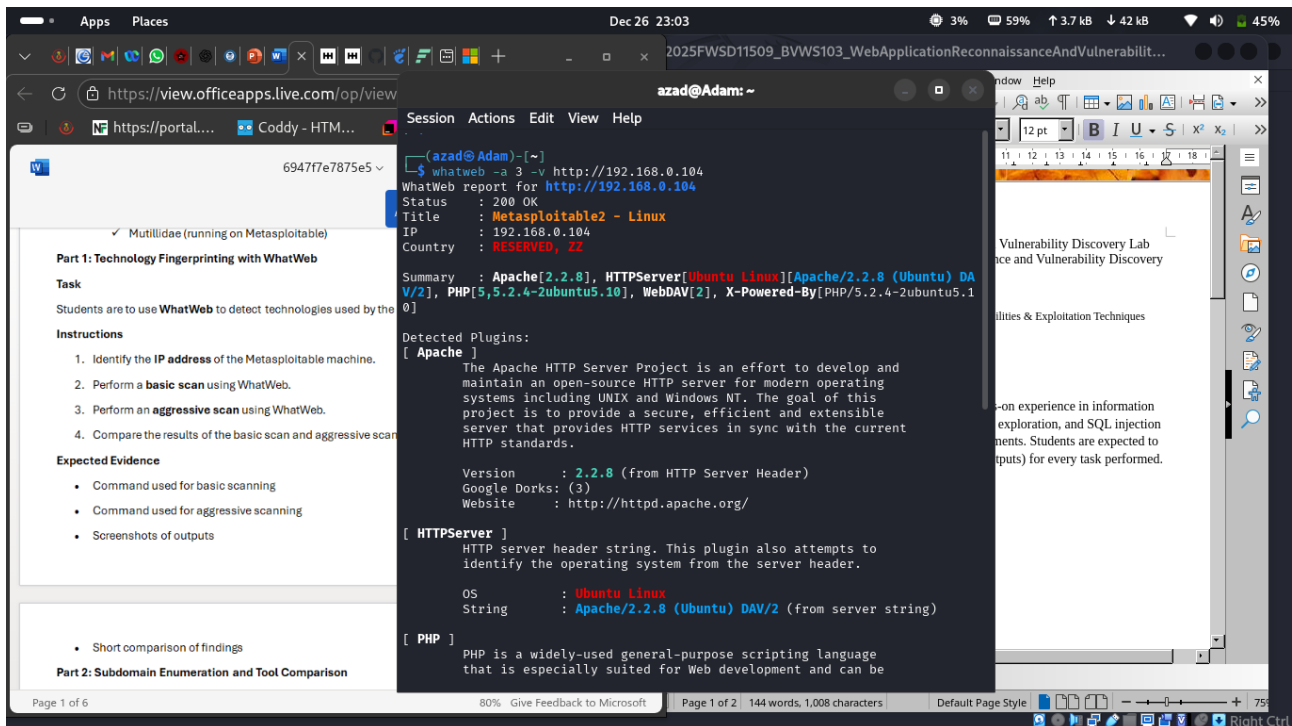
Short comparison of findings

Part 2: Subdomain Enumeration and Tool Comparison

Page 1 of 6

```
(azad@Adam)-[~]
$ whatweb http://192.168.0.104
http://192.168.0.104 [200 OK] Apache[2.2.8], Country[RESERVED][??], HTTPServ
er[Ubuntu Linux][Apache/2.2.8 (Ubuntu) DAV/2], IP[192.168.0.104], PHP[5.2.4-
2ubuntu5.10], Title[Metasploitable2 - Linux], WebDAV[2], X-Powered-By[PHP/5.
2.4-2ubuntu5.10]
```

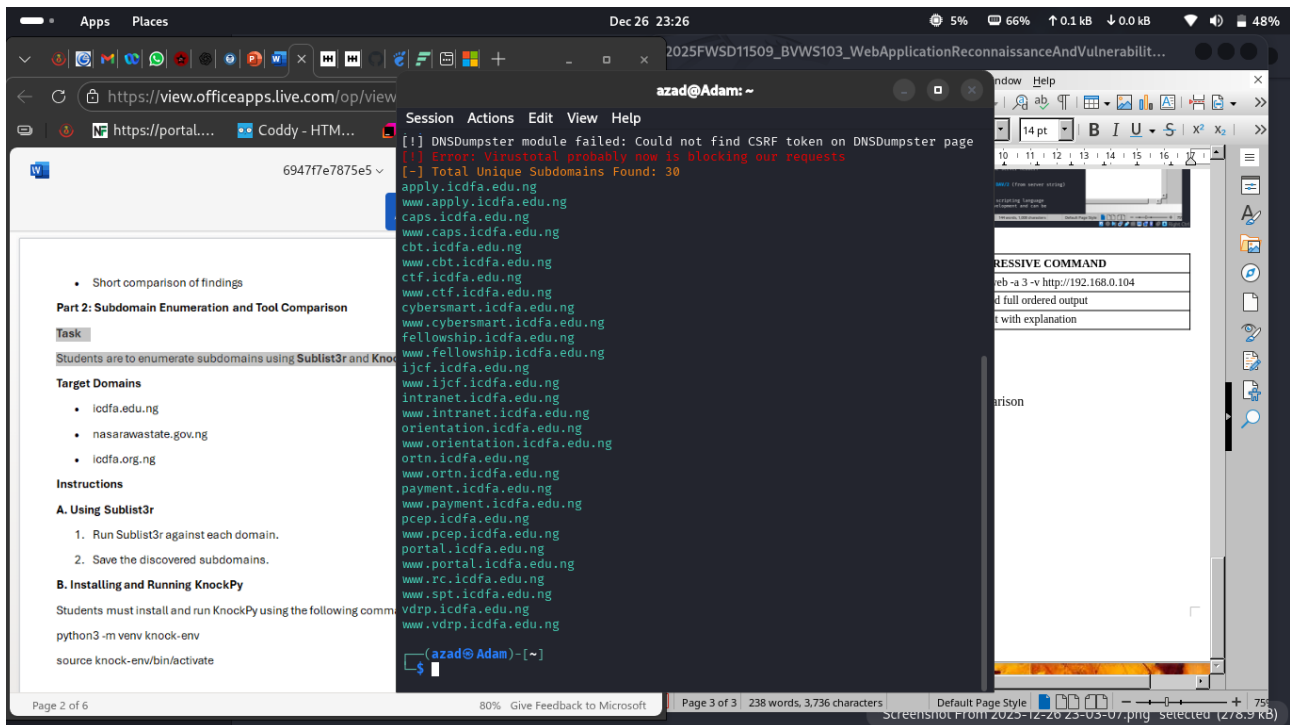
From the aggressive scan the whatweb fetch a lot of data from database and give the output in perfect order using the commands
 whatweb -a 3 -v http://192.168.0.104



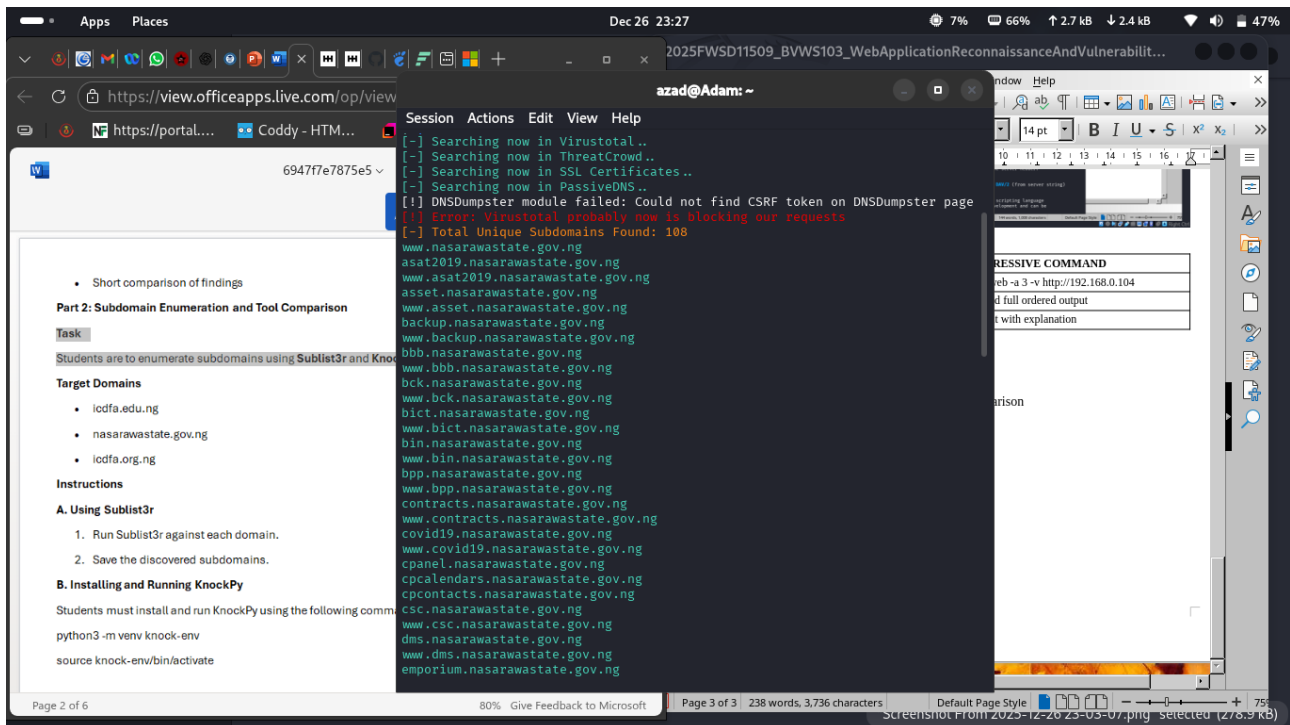
BASIC COMMAND	AGGRESSIVE COMMAND
whatweb http://192.169.0.104	whatweb -a 3 -v http://192.168.0.104
Shot and brive output	All and full ordered output
Output without explanation	Output with explanation

Part 2: Subdomain Enumeration and Tool Comparison

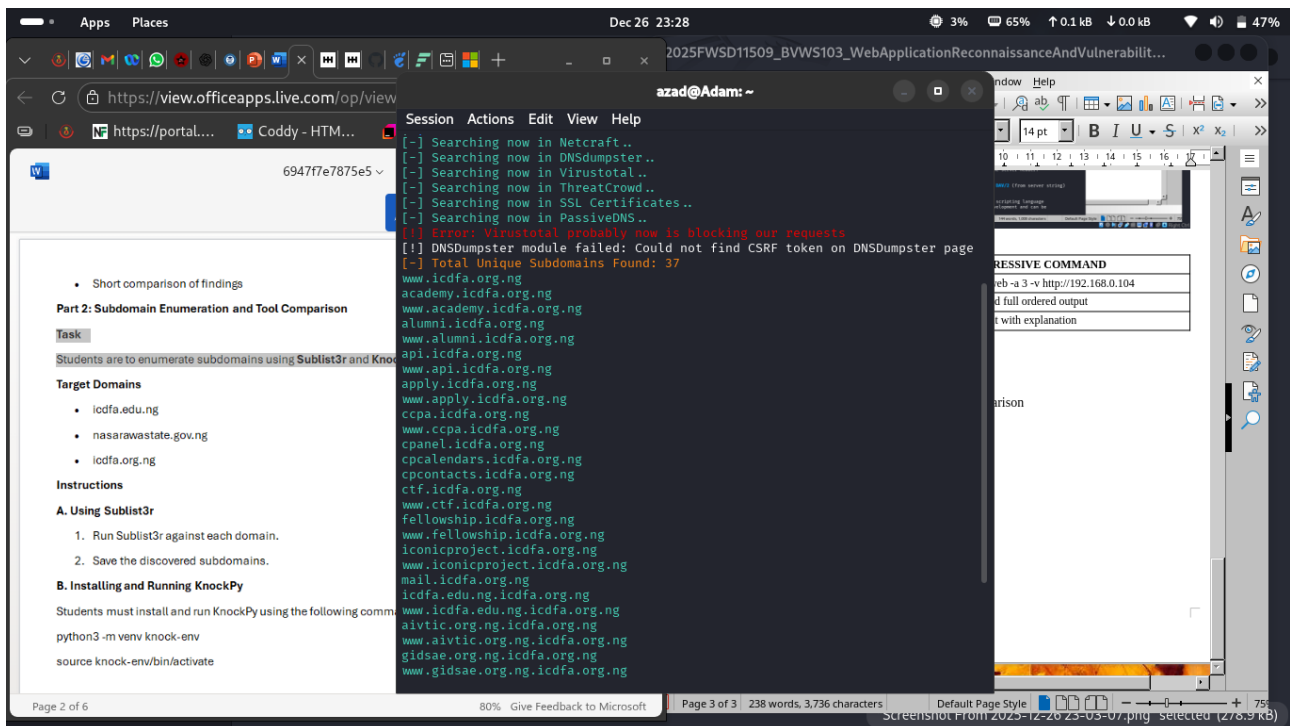
from the sublist3r, in finding the first result i used the command `sublist3r -d icdfa.edu.ng` and i got 30 subdomain



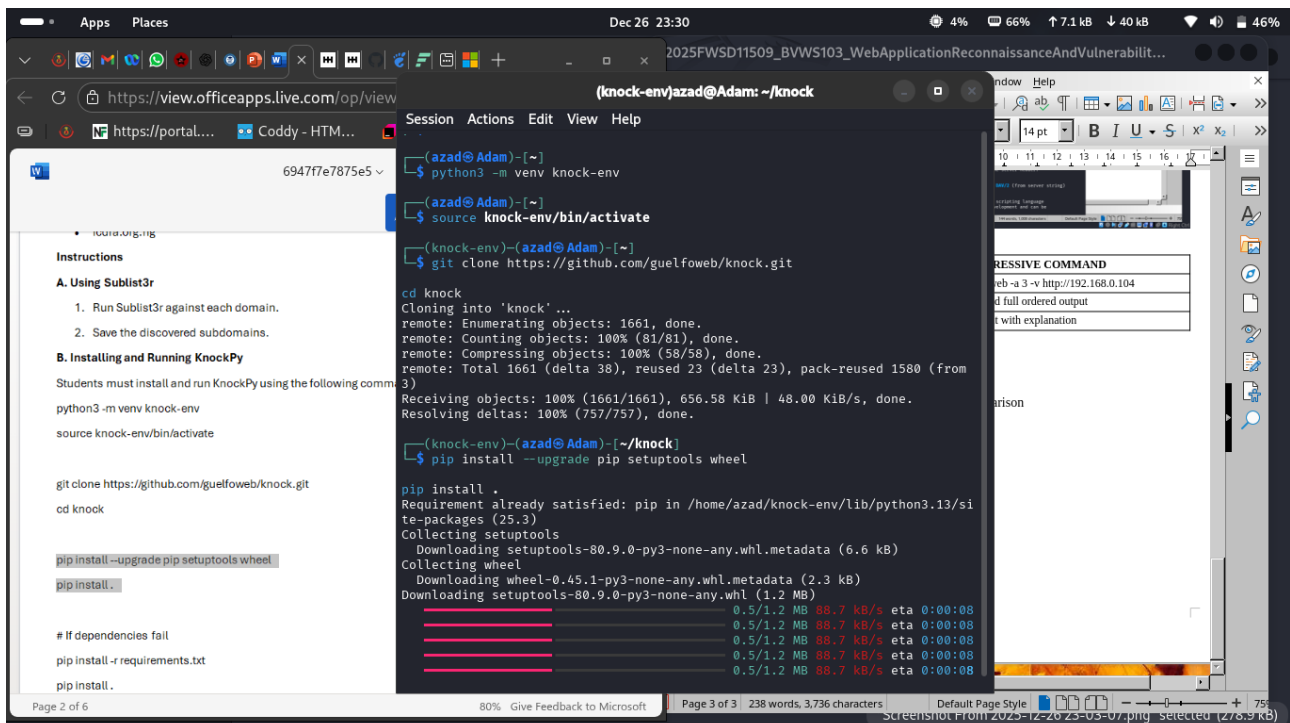
in the second aspect that i use `sublist3r -d nasarawastate.gov.ng` i fund 108 subdomain



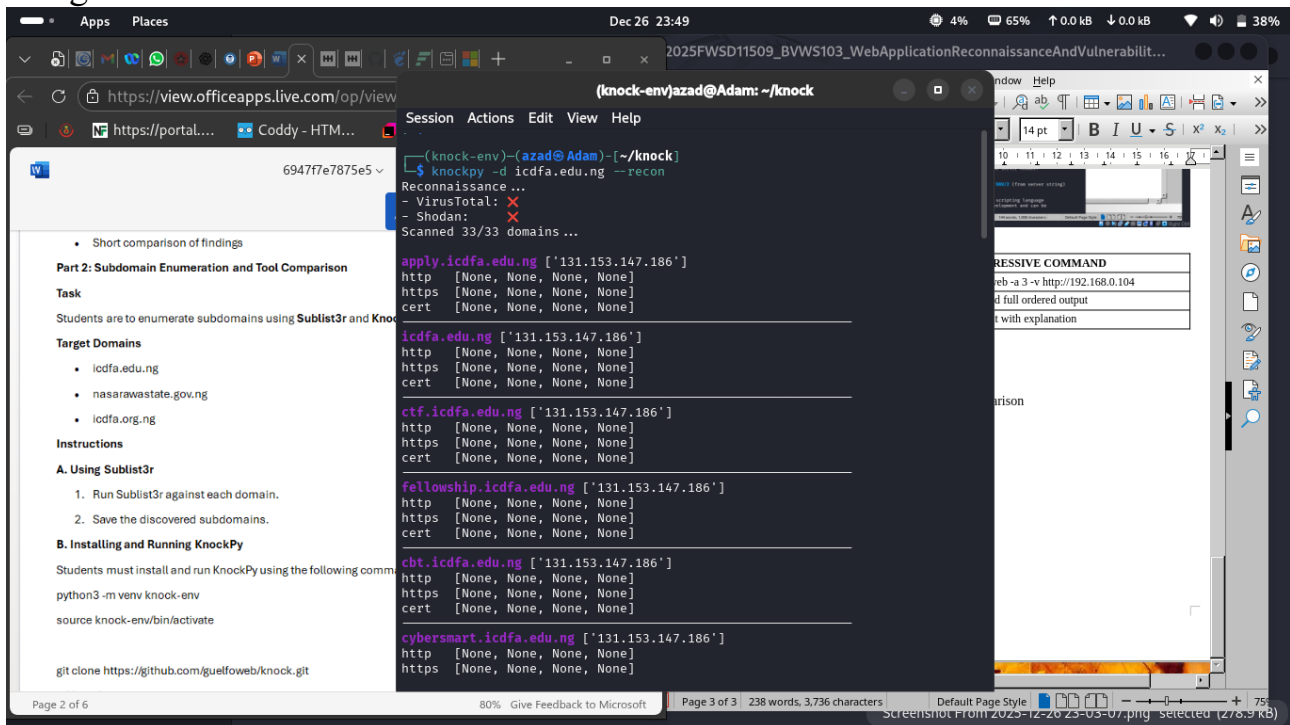
and at the last part in sublist3r i go for sublist3r -d icdfa.org.ng and got 37 subdomains



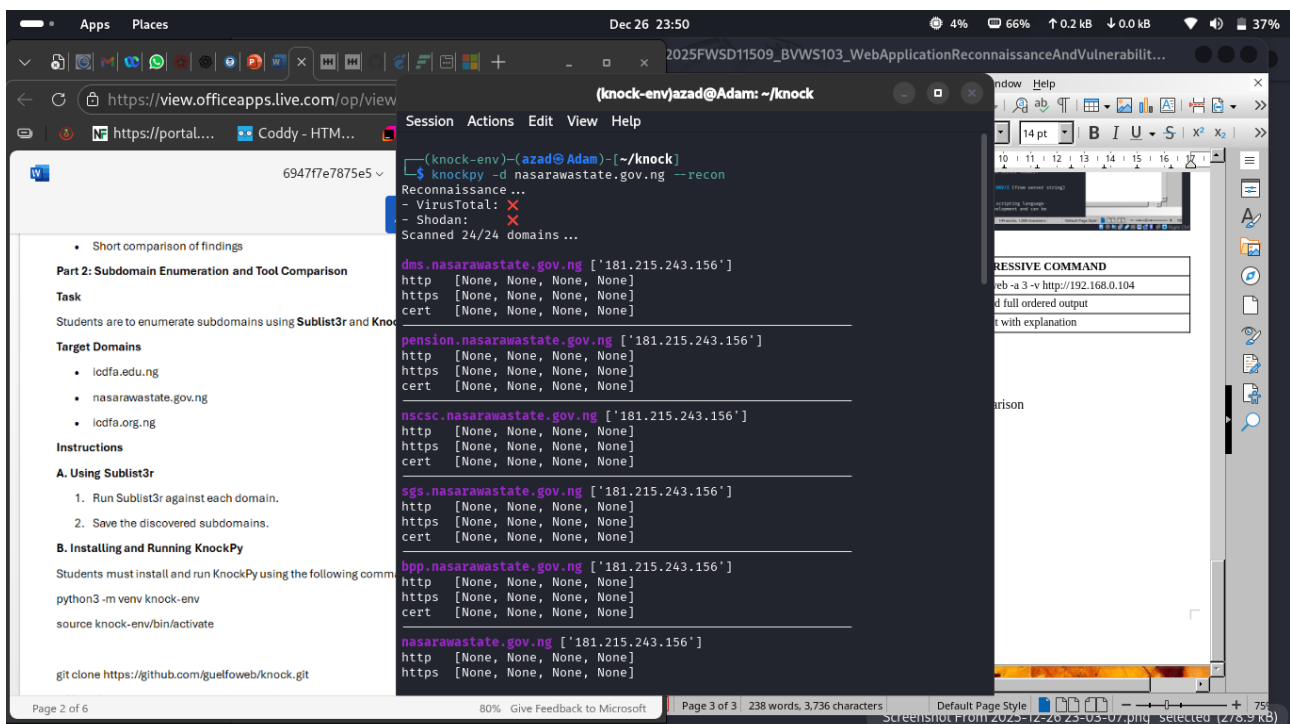
i proceed with the installation of knockpy and everything is perfect and good



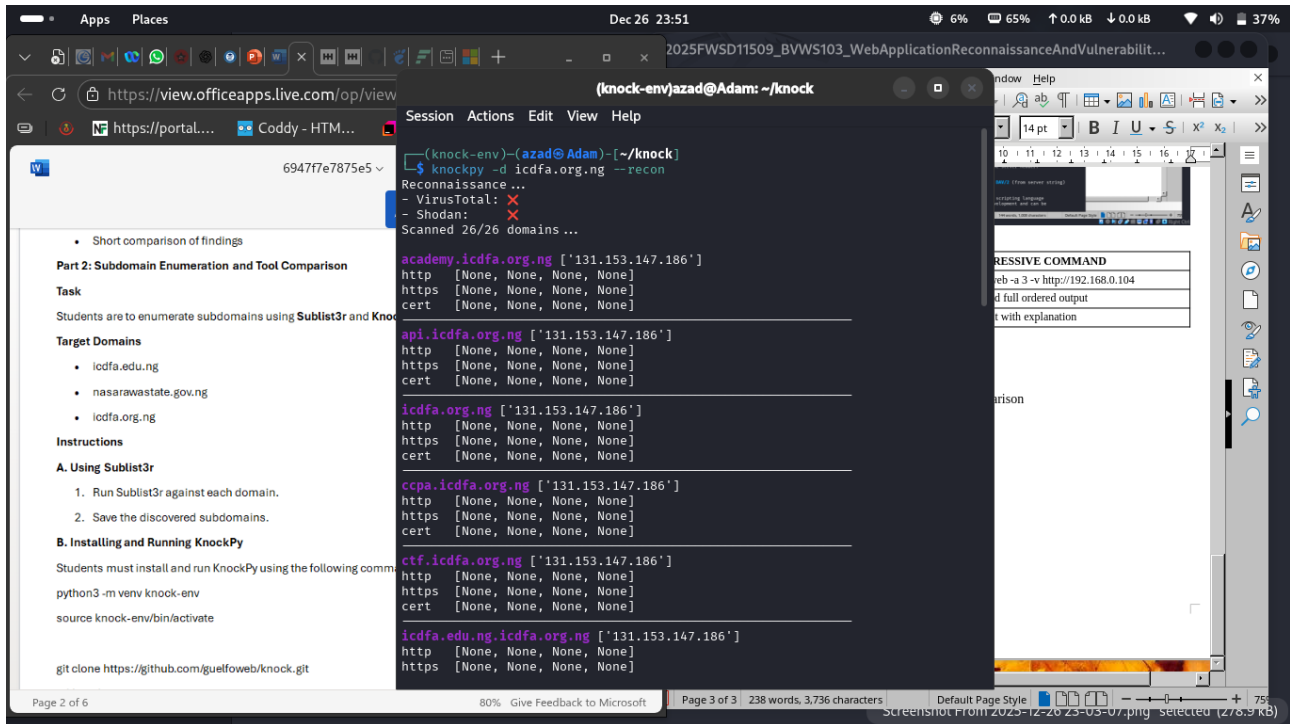
this is the first try of knockpy which i used the commands `knockpy -d icdfa.edu.ng --recon` and got 33 subdomains



in this second part that i used `knockpy -d nasarawastate.gov.ng --recon` i got 24 subdomains



and lastly that i used `knockpy -d icdfa.org.ng --recon` i got 26 subdomains

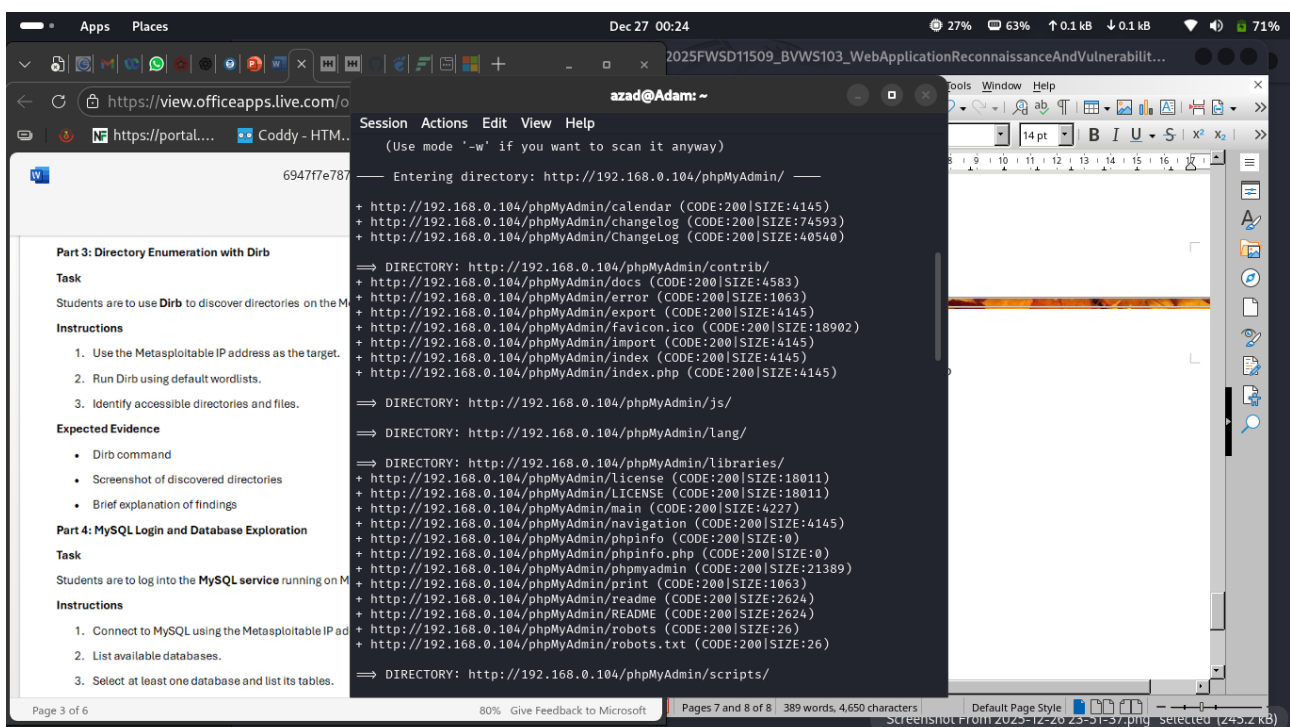
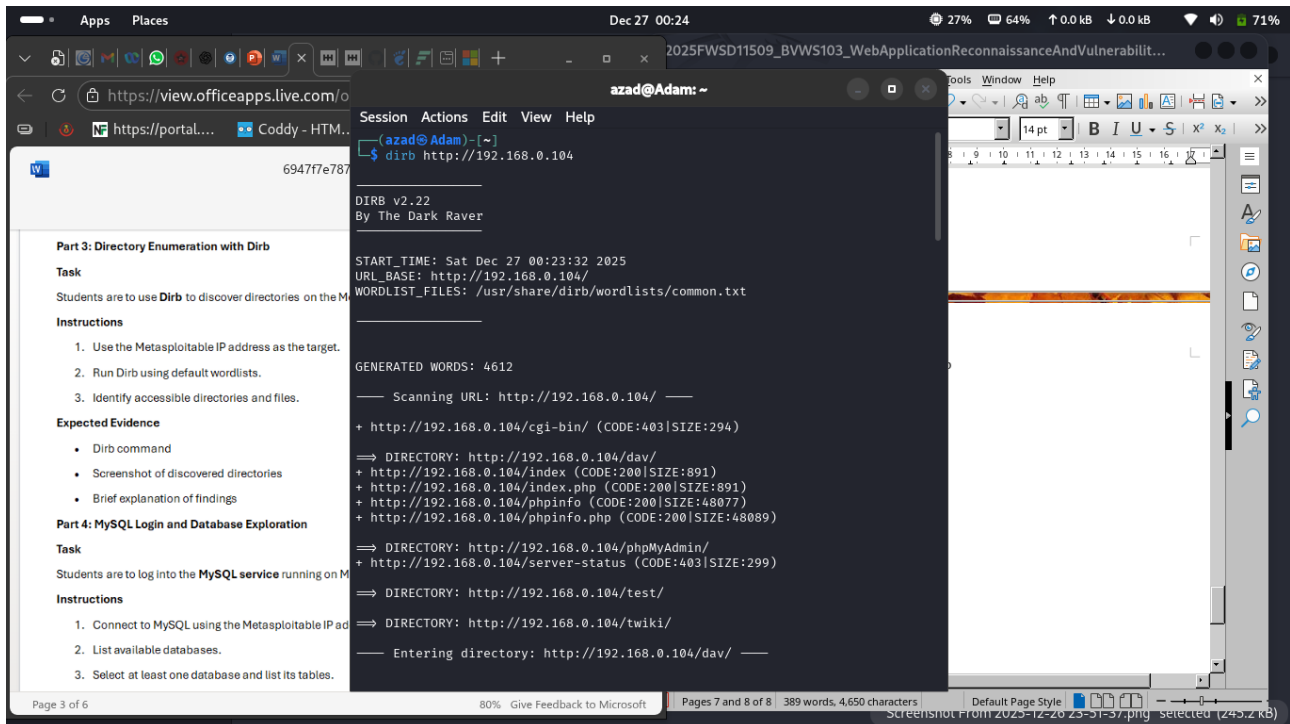


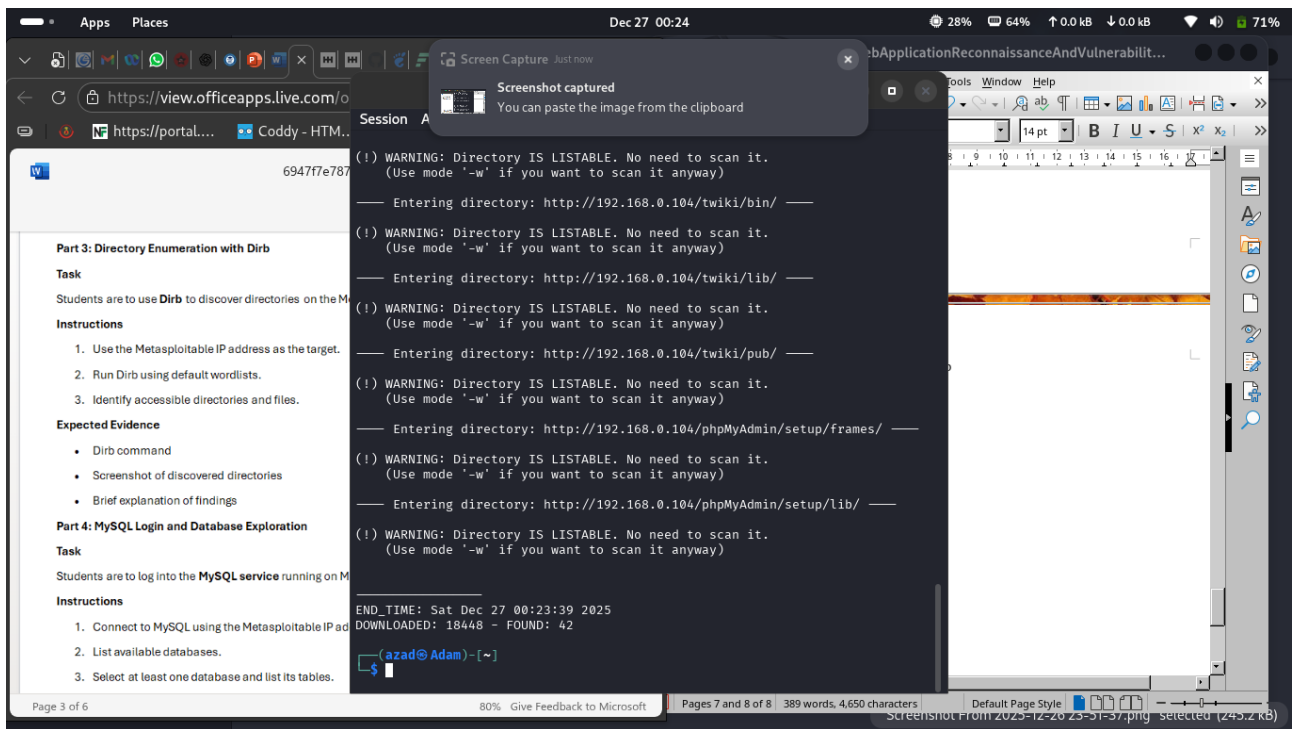
Sublist3r is fast and stealthy but limited to public information, while KnockPy performs deeper enumeration through active probing.

SUBLIST3R	KNOCKPY
OSINT-based	DNS brute-force
Fast	Slower
It include the www	Only the ordnary subdomains

Part 3: Directory Enumeration with Dirb

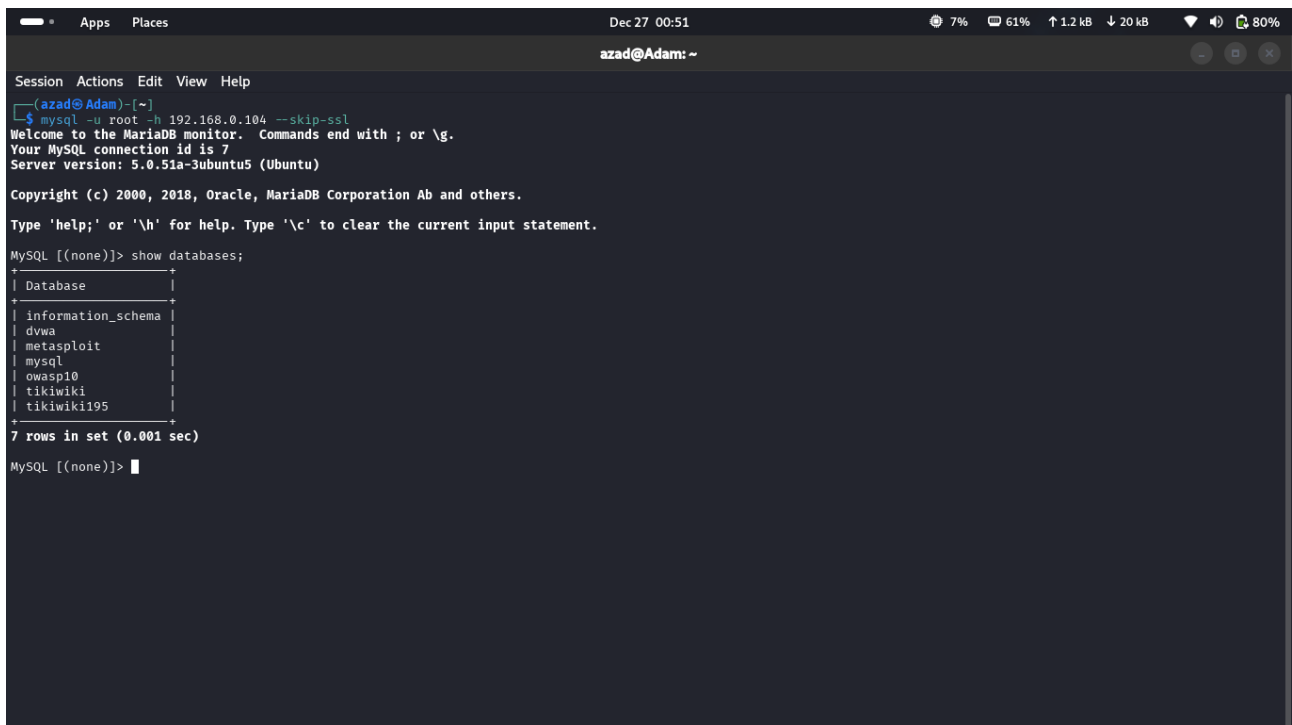
I used my metasploitable2 IP address on this part and the command dirb http://192.168.0.104 and i got 43 diffrent direcctoris present in. By using this method if you make a scan in a perticular website and find alot like this that means you can do what you like in that side





Part 4: MySQL Login and Database Exploration

In this aspect i login into my metaspolitable2 database and exploe the databases using the command : `mysql -u root -h 192.168.0.104 --skip-ssl`. then explore the tables



```
Dec 27 00:55
azad@Adam: ~

Session Actions Edit View Help
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> show databases;
+-----+
| Database |
+-----+
| information_schema |
| dvwa      |
| metasploit |
| mysql     |
| owasp10   |
| tikiwiki  |
| tikiwiki195 |
+-----+
7 rows in set (0.001 sec)

MySQL [(none)]> select metasploit;
ERROR 1054 (42S22): Unknown column 'metasploit' in 'field list'
MySQL [(none)]> select metasploit
→ 'c'
MySQL [(none)]> use owasp10
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MySQL [owasp10]> show tables;
+-----+
| Tables_in_owasp10 |
+-----+
| accounts          |
| blogs_table       |
| captured_data     |
| credit_cards      |
| hitlog            |
| pen_test_tools    |
+-----+
6 rows in set (0.000 sec)

MySQL [owasp10]> 
```

Part 5: First-Order SQL Injection in Mutillidae

A. Low Security (Hosed / Security Level 0)

in this part i first of all create an accout and the try to inject my firs-order SQL injection to login

Dec 27 01:5529%64%↑ 2.8 kB↓ 119 kB80%

Kali Linux192.168.0.104/mutillidae/ × +

← → ↻ ↺ Not Secure http://192.168.0.104/mutillidae/index.php?page=register.php ☆

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB Inbox (163) - adambas...

**Mutillidae: Born to be Hacked**

Version: 2.1.19 Security Level: 0 (Hosed) Hints: Disabled (0 - I try harder) Not Logged In

Home Login/Register Toggle Hints Toggle Security Reset DB View Log View Captured Data

Core Controls >OWASP Top 10 >Others >Documentation >Resources >

Site hacked...err...quality-tested with Samurai WTF, Backtrack, Firefox, Burp-Suite, Netcat, and these Mozilla Add-ons

Register for an Account

 Back

Account created for Azad. 1 rows inserted.

Please choose your username, password and signature

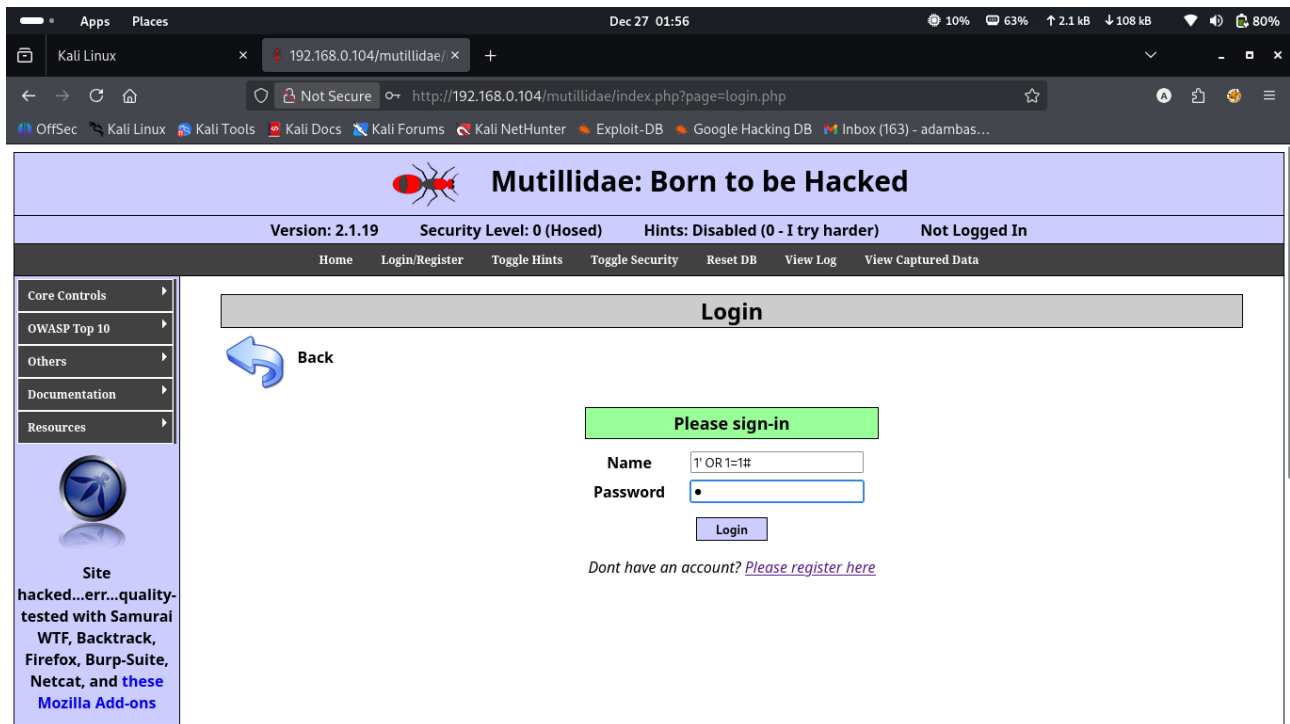
Username

Password

Confirm Password

Signature

this is the process of injection using the payload 1' OR 1=1#

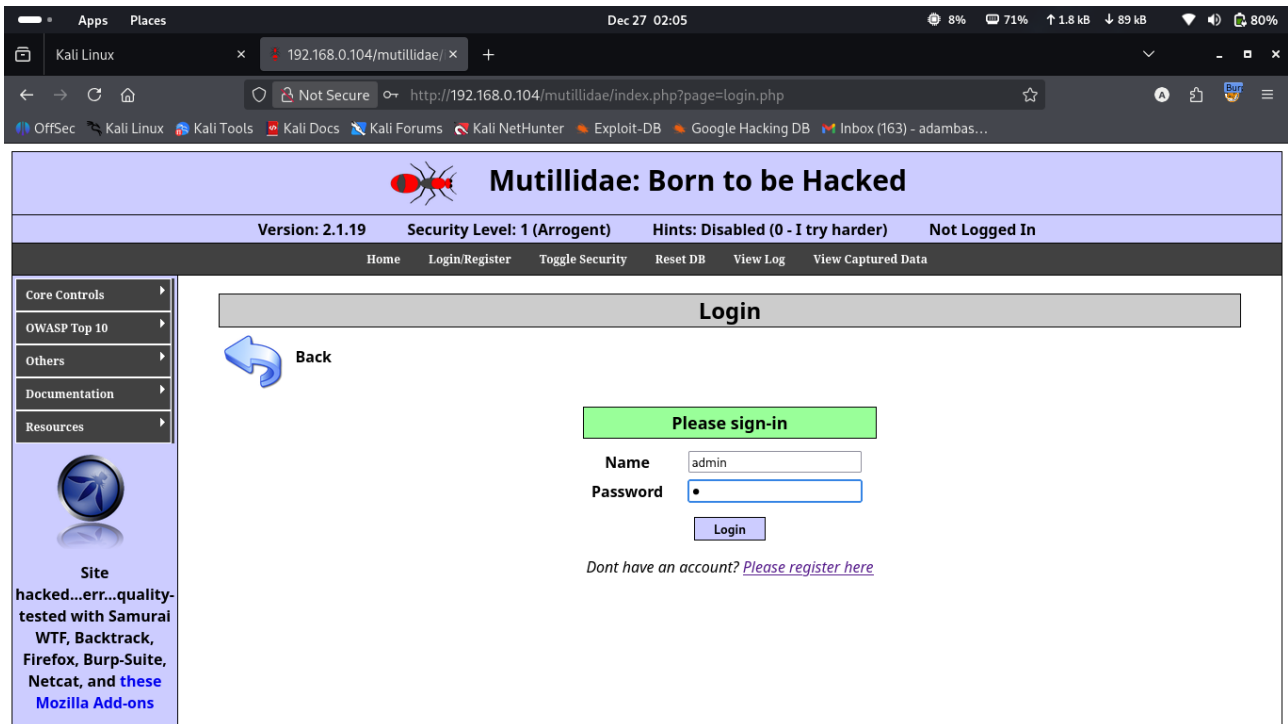


this shows that i have successfully logged in as admin

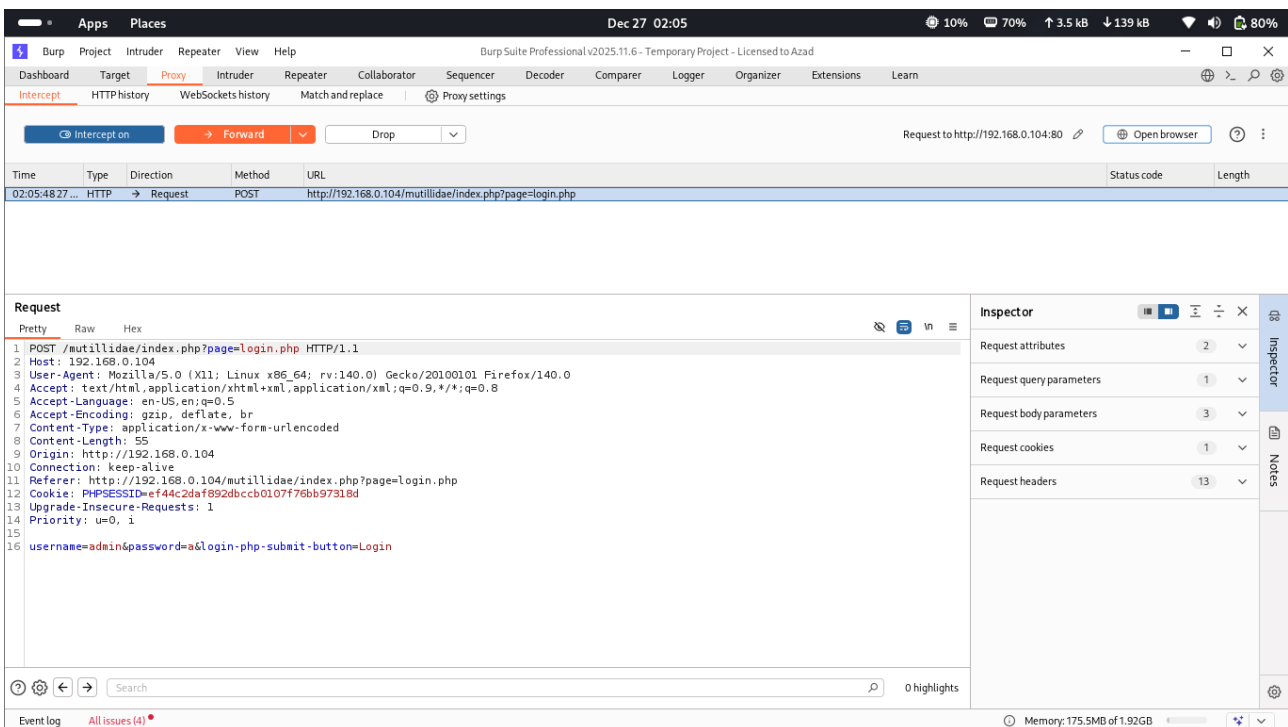


B. Higher Security (Manual Exploitation)

i start by lunching my burpsute then on my interceptor and go to my browser and on my proxy burp and click login



my request was sand to burpsute to inspect

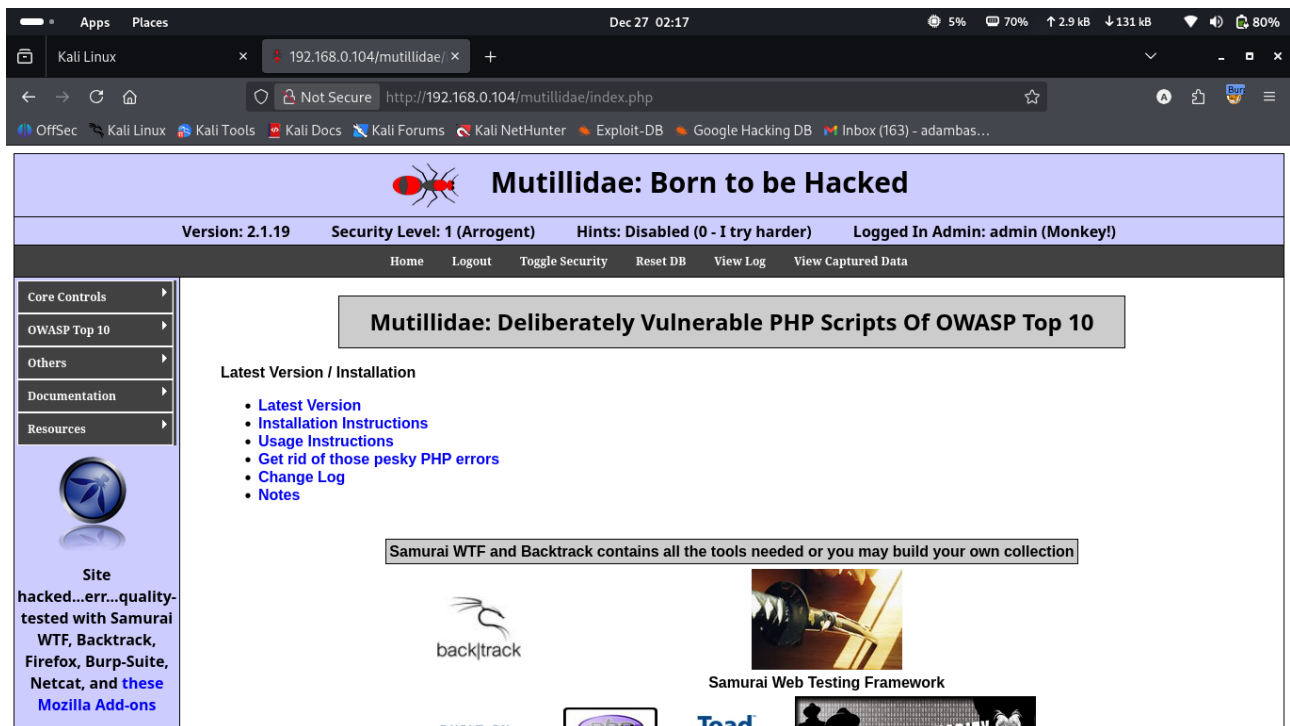


i then modify my payload and inject in trough the burp and forward the request

The screenshot shows the Burp Suite Professional interface. The top menu bar includes 'Burp', 'Project', 'Intruder', 'Repeater', 'View', and 'Help'. The toolbar has buttons for 'Intercept on', 'Forward', and 'Drop'. The main window displays an intercepted HTTP POST request to `http://192.168.0.104/mutillidae/index.php?page=login.php`. The request details are shown in the 'Request' tab, and the 'Inspector' panel on the right shows the request body parameters, including 'username=admin&password=a&login-php-submit-button=Login'.

my injection was successfull and am so happy for that i did it my self

The screenshot shows a web browser displaying the Mutillidae application. The page title is 'Mutillidae: Born to be Hacked'. The interface includes a navigation menu on the left with options like 'Core Controls', 'OWASP Top 10', and 'Resources'. The main content area shows a 'Login' form with a 'Back' button and a message 'You are logged in as admin' with a 'Logout' button.



Part 6: POST vs GET Requests (No AI Assistance)

GET Request: this is the process where by you send a request to the server in order to retrieve back data for you.

Its normally used for: searching content, loading webside, fetching public data etc

POST Request: this is the type of request where by you use to send data to the server for documenting of filling a form.

Its normally used in: Registration forms, uploading data, login forms etc.

Part 7: Information Gathering in Web Application Security

Information gathering is the first and most important phase in web application security because it helps to understand how a target system works before any attack or defense is attempted. Without proper information, both attackers and defenders would be working blindly.

Part 8: How Websites Work (Request–Response Model)

A website works through a simple communication process between the client (browser) and the server.

Step-by-step:

- The user enters a website or clicks a link.
- The browser sends a **request** to the web server.
- The server processes the request.
- The server sends a **response** back to the browser.
- The browser displays the webpage to the user.

When a user types a domain name like `www.example.com`, the following steps occur:

1. The browser checks if the address is already saved in its cache.
2. If not found, the browser asks the **DNS server** for the IP address.
3. The DNS server responds with the correct IP address.
4. The browser sends an HTTP or HTTPS request to that IP address.
5. The web server processes the request.
6. The server sends back the webpage.
7. The browser renders and displays the page.

The DNS (Domain Name System) acts like the internet's phonebook.

Its role:

- Converts human-readable domain names into IP addresses
- Helps browsers locate the correct web server
- Makes the internet easier to use without memorizing numbers

Part 9: Role of Burp Suite in Web Application Penetration Testing

1. Role of Burp Suite in Web Application Penetration Testing

Burp Suite is one of the most important tools used in web application penetration testing. It helps security testers understand, analyze, and test how a web application communicates with users through HTTP and HTTPS.

2. Intercepting Requests

One key role of Burp Suite is intercepting requests between the browser and the web server. When interception is enabled, Burp Suite sits in the middle and captures requests before they reach the server. This allows testers to see exactly what data is being sent, such as login details, cookies, headers, and form inputs.

By intercepting requests, testers gain full visibility into how the application works behind the scenes.

3. Modifying Parameters

Burp Suite allows testers to modify request parameters before sending them to the server. For example, a tester can change:

- User IDs
- Prices
- Roles
- Form values

This helps in checking whether the application properly validates user input. If the application accepts manipulated values, it may indicate serious security flaws such as privilege escalation or parameter tampering.

4. Testing Vulnerabilities

Burp Suite is widely used to test common web vulnerabilities, including:

- SQL Injection
- Cross-Site Scripting (XSS)
- Authentication flaws
- Session management issues

Tools like Repeater, Intruder, and Scanner help testers send repeated or automated requests to observe how the application responds to different inputs. This makes vulnerability testing more effective and controlled.

5. Why Burp Suite Is Important for Security Testers

Burp Suite is important because it provides:

- Full control over web traffic
- Deep insight into application behavior
- Accurate testing of real-world attack scenarios

For security testers, Burp Suite bridges the gap between theory and practical testing. It allows them to identify vulnerabilities before attackers do and helps organizations secure their web applications.